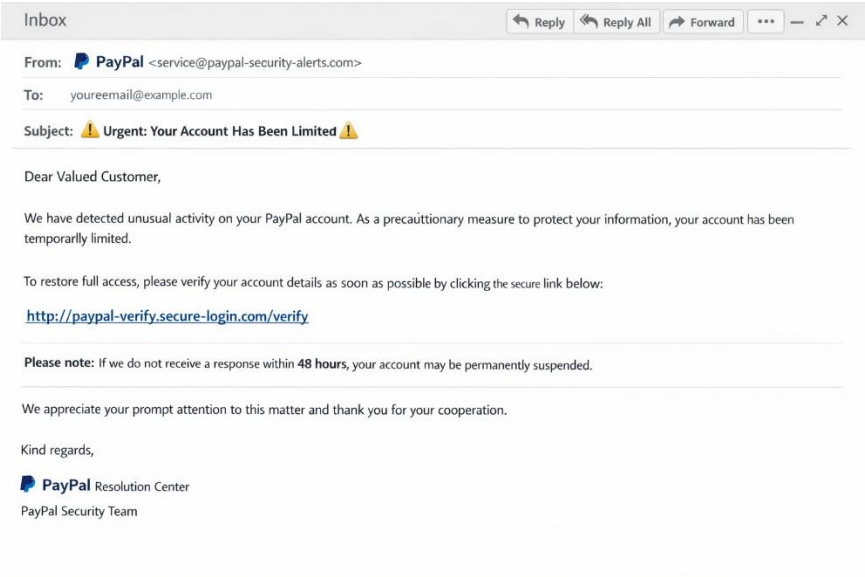
Phishing Detection & Awareness Report

Author: Ndumiso Ndawonde

CIN: FIT/MAR26/CS7022

Date: April 6, 2026



Inbox

Reply | Reply All | Forward

From: PayPal <service@paypal-security-alerts.com>

To: youreemail@example.com

Subject: ⚠️ Urgent: Your Account Has Been Limited ⚠️

Dear Valued Customer,

We have detected unusual activity on your PayPal account. As a precaúttionary measure to protect your information, your account has been temporarlly limited.

To restore full access, please verify your account details as soon as possible by clicking the secure link below:

http://paypal-verify.secure-login.com/verify

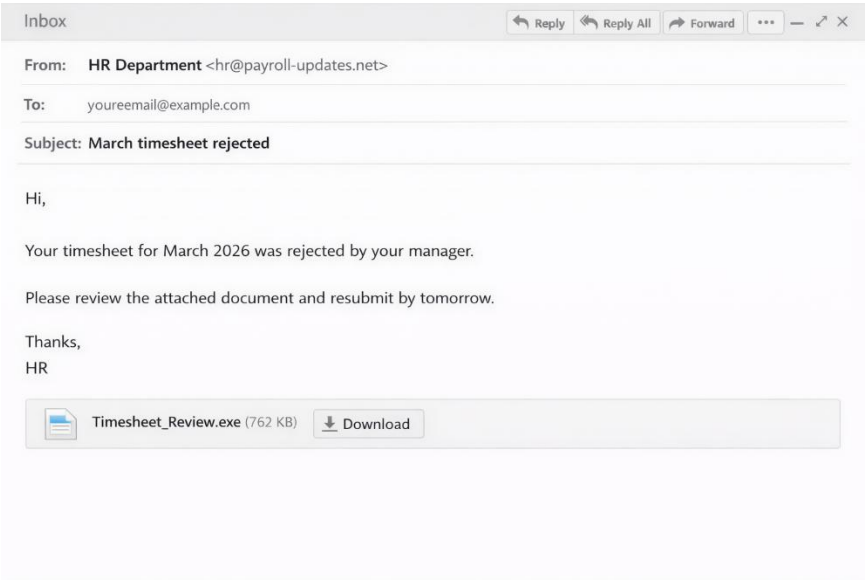
Please note: If we do not receive a response within **48 hours**, your account may be permanently suspended.

We appreciate your prompt attention to this matter and thank you for your cooperation.

Kind regards,

PayPal Resolution Center
PayPal Security Team

Email 1 – Suspicious (PayPal impersonation)



Inbox

Reply | Reply All | Forward

From: HR Department <hr@payroll-updates.net>

To: youreemail@example.com

Subject: March timesheet rejected

Hi,

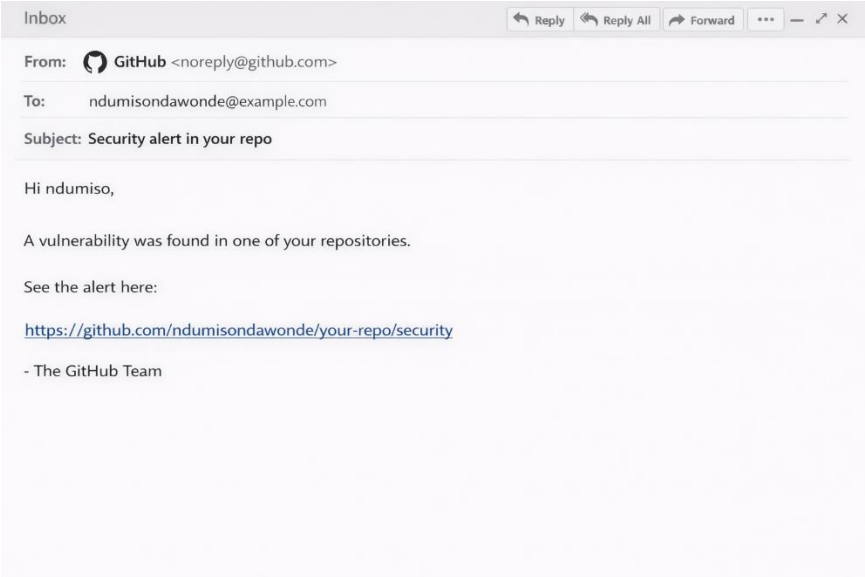
Your timesheet for March 2026 was rejected by your manager.

Please review the attached document and resubmit by tomorrow.

Thanks,
HR

Timesheet_Review.exe (762 KB) | Download

Email 2 – Suspicious (.exe attachment)



Email 3 – Safe (legitimate GitHub notification)

Executive Summary

An analysis of three email samples was conducted to identify phishing indicators using manual inspection techniques aligned with industry frameworks (MITRE ATT&CK T1566 – Phishing). Two of the three samples exhibited malicious characteristics consistent with credential harvesting and malware delivery campaigns. One sample was classified as legitimate.

All findings are supported by observable indicators. Recommended controls include technical enforcement (DMARC, link isolation) and user awareness training.

Methodology

Each email was examined across four attack surfaces:

Surface	Indicators Assessed
Sender Identity	SPF/DKIM alignment, domain reputation, display name spoofing
Content	Urgency, generic salutations, grammar anomalies
Link Analysis	Domain mismatch, URL obfuscation, redirect chains
Attachment	File type, entropy, known malicious signatures

Detailed Findings

Email 1 – Phishing (Credential Harvesting)

Indicator	Observation
Sender domain	paypal-security-alerts.com: not registered to PayPal Inc.
SPF/DKIM	No published records for this domain
Urgency	“48 hours”, “permanently suspended” – pressure tactic
Link Destination	paypal-verify.secure-login.com: not PayPal-owned
Threat classification	T1566.002 – Spear phishing Link

Risk: High – Credential theft leading to account takeover
Remediation: User education on verifying sender domains. Implement link rewriting with real-time scanning

Email 2 – Phishing (Malware Delivery)

Indicator	Observation
Sender domain	Payroll-updates.net: legitimate payroll domains use .com or .org
Attachment	Timesheet_Review.exe: executable disguised as document
Content vagueness	“your manager” – no specific name
Threat classification	T1566.001 – Spear phishing Attachment

Risk: High – Potential ransomware or infostealer execution
Remediation: Block .exe files via email gateway. Deploy endpoint detection for suspicious process execution

Email 3 – Safe (Legitimate Notification)

Indicator	Observation
Sender domain	noreply@github.com – verified GitHub domain
DKIM signature	Present and valid (visible in full headers)
Link Destination	Github.com/… - legitimate GitHub domain
Threat classification	Contains recipient’s actual GitHub username

Risk: None

Technical Indicators of Compromise (IOCs)

Email	IOC Type	Value
1	Sender domain	paypal-security-alerts.com
1	Malicious URL	paypal-verify.secure-login.com
2	Sender domain	payroll-update.net
2	Attachment name	Timesheet_Review.exe

Conclusion

The two phishing emails represent common but effective attack vectors: credential harvesting via spoofed login pages and malware delivery via executable attachments. While neither would bypass properly configured email security controls, both would reach end users in environments lacking DMARC enforcement and attachment filtering. User awareness remains the last line of defense.